

Tech Talk 15

AWS Bedrock을 이용한 로그인 보안 관제

SIPE 5기 이상원

하루에도 수십 수천만 건의
로그인이 발생합니다.

그 중에 공격이 섞여 있다면,
우리는 실시간으로 알 수 있을까요?

Contents

- 01 로그인 공격 탐지가 왜 어려운가
- 02 크리덴셜 스테핑 공격의 특징과 위험성
- 03 기존 모니터링의 한계점
- 04 사람이 하던 판단을 LLM으로 옮기기
- 05 AWS Bedrock 기반 탐지 시스템 설계 및 프로세스
- 06 분석 결과 도입 후 성과

로그인 공격 탐지가 왜 어려운가

- 정상 요청 사이에 공격이 섞여 들어온다
- 실제 사용자처럼 보이기도 한다
- 비정상 패턴 로그인 of 맥락을 판단해야 한다

크리덴셜 스테핑 공격이란?

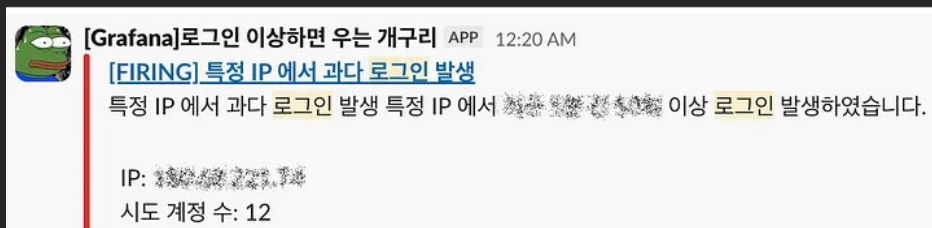
- 다른 서비스에서 유출된 ID/PW 목록으로 대규모 로그인 시도
- 다크 웹에서 취득한 자격증명 이용
- 같은 ID/PW를 여러 사이트에 사용하는 허점을 이용

ID, PW를 여러 사이트에 똑같이 사용하시는 분 있으신가요?
공격자는 이 허점을 이용하는 겁니다!

크리덴셜 스테핑 공격의 위험성

- 실제 사용자 계정 정보를 사용하기 때문에 성공 확률이 높음
- 정상 사용자처럼 보여 탐지 어려움 (낮은 실패율, 합법적 트래픽 흉내)
- 자동화된 공격 가능
- 개인정보 보안 사고로 이어질 수 있음

기존 모니터링의 한계점

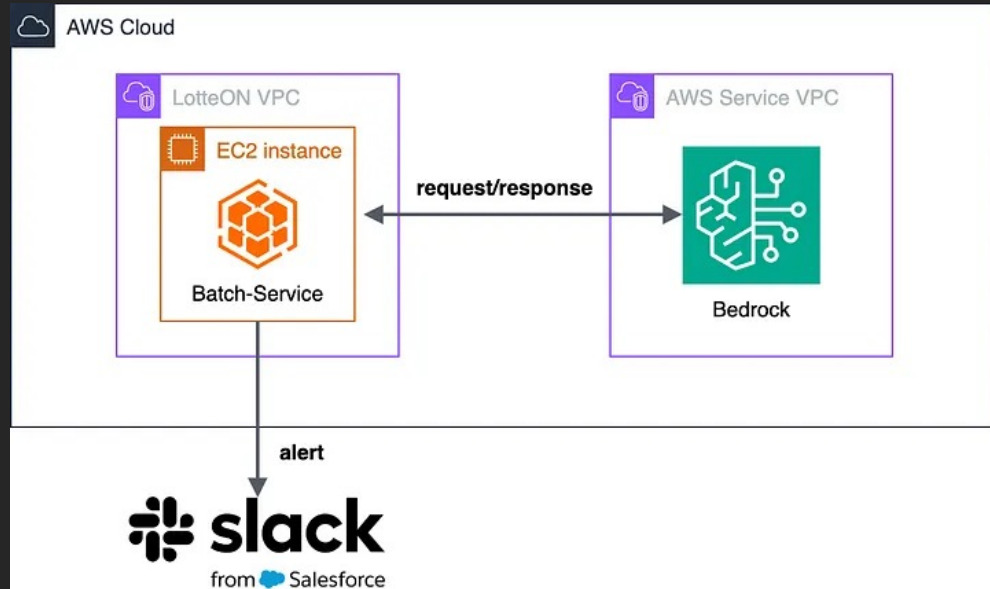


- 크리덴셜 스테핑 공격인지 어뷰징인지 즉시 판단 불가
- 개발자가 직접 데이터 확인 필요
- 야간, 휴일의 경우 대응 속도가 매우 느림

LLM을 이용한 로그인 이력 분석 도입

- 쿼리로 분석하기에는 한계가 존재
- 어뷰징 시도의 경우 전화번호가 오름차순이거나 이메일 숫자가 동일
- 비정상 로그인 시도에 대한 맥락 파악을 위해 LLM 기반 분석 도입

AWS Bedrock 기반 로그인 보안 관제 아키텍처



- 외부 인터넷을 타지 않고 vpc 내부 통신이 가능
- 응답을 저장하지 않는 stateless한 특징

Bedrock 기반 보안 관제 동작 프로세스

1

로그인 이력 조회

배치 서비스가
로그인 이력 조회 →
비정상 패턴 감지

>

2

Bedrock 분석 요청

연관 정보 추가 조회 →
Bedrock에 분석 요청

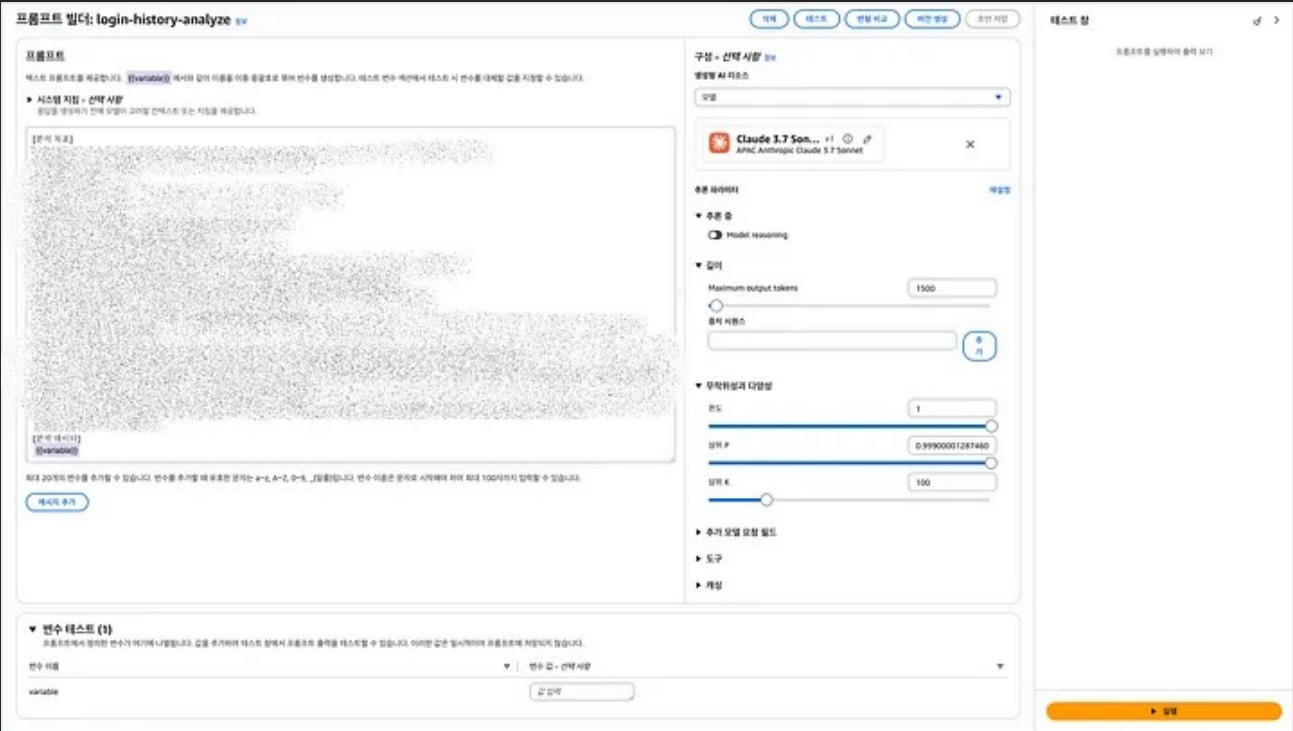
>

3

Slack 알림 전송

분석 결과 Slack 전송 →
실시간 정황 파악

Bedrock에서 프롬프트 테스트와 관리하기

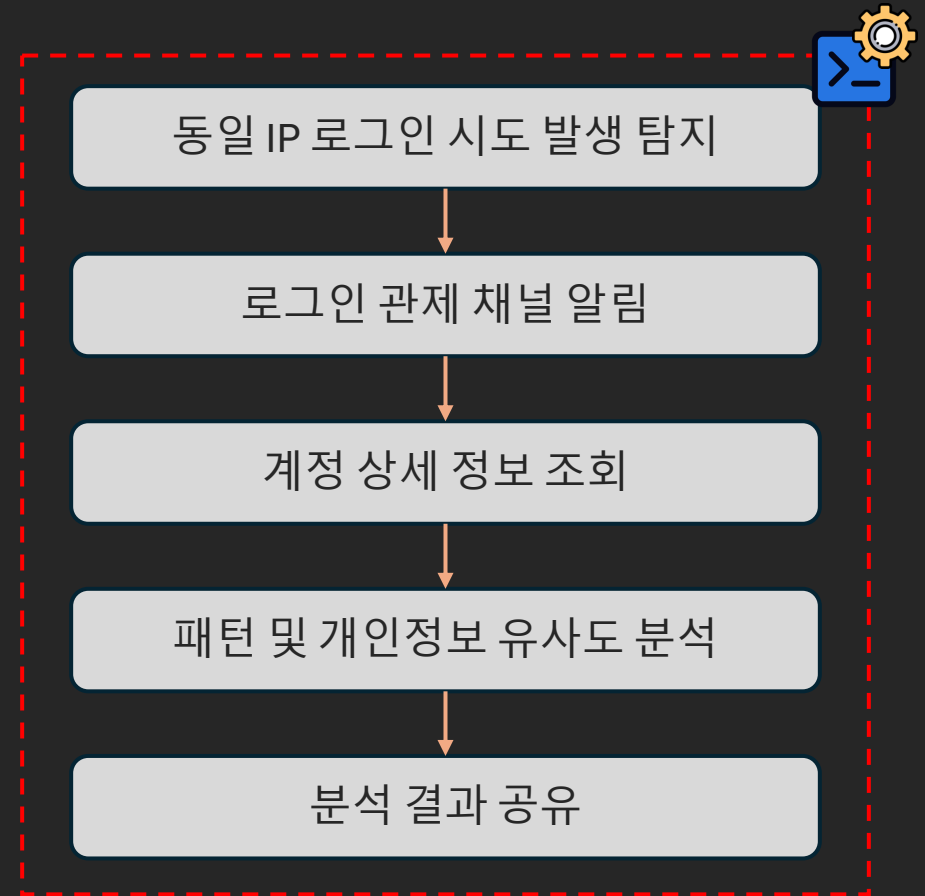
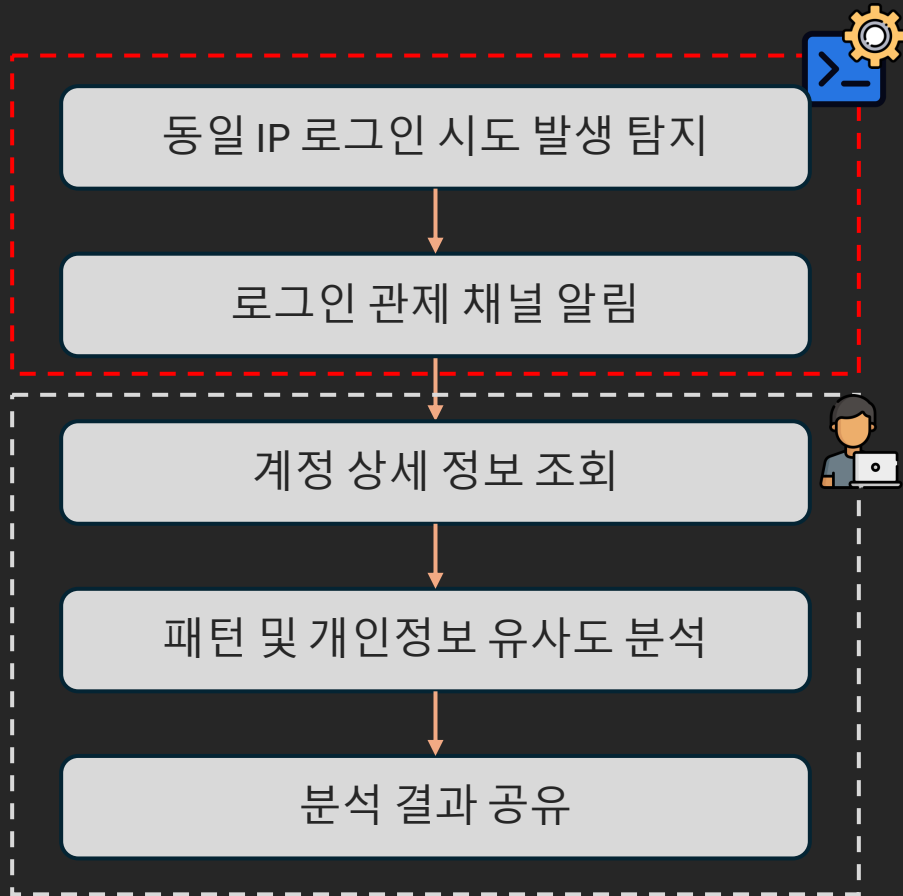


- 프롬프트 버전 관리
- 별도 배포 없이 즉시 반영 가능

실제 분석 결과 알림 예시

[illegible]

분석 결과 도입 후 성과



감사합니다

Q&A